

KPIs Y KRIs EN POLÍTICAS DE SEGURIDAD Y SIMULACRO DE COMITÉ DE SEGURIDAD

Material de aula · RA1 · Planes de prevención y concienciación

Objetivo del documento. Comprender cómo se diseñan, calculan e interpretan los indicadores clave de rendimiento (KPI) y los indicadores clave de riesgo (KRI) en ciberseguridad, y aplicarlos al ciclo de vida de una Política General de Seguridad. El documento finaliza con un simulacro práctico de comité de seguridad en el que el alumnado deberá trabajar alcance, responsabilidades, aprobación, revisión, excepciones, incumplimientos y métricas de rendimiento y riesgo.

Diccionario de siglas y abreviaturas

La primera aparición de una sigla debe interpretarse según esta tabla. Se incluyen todas las abreviaturas y siglas empleadas en este material.

Sigla	Significado original	Traducción / significado	Explicación sencilla
BYOD	Bring Your Own Device	Trae tu propio dispositivo	Política que permite utilizar dispositivos personales, como móviles o portátiles, para acceder a recursos corporativos.
CMDB	Configuration Management Database	Base de datos de gestión de configuración	Base de datos donde se registran activos tecnológicos, configuraciones y relaciones entre sistemas. En este documento se utiliza como fuente para detectar sistemas EOL/EOS.
EOL	End of Life	Fin de vida	Momento en que un producto o versión llega al final de su ciclo de vida y deja de evolucionar normalmente.
EOS	End of Support	Fin de soporte	Momento a partir del cual el fabricante deja de proporcionar soporte, correcciones o actualizaciones de seguridad.
IAM	Identity and Access Management	Gestión de identidades y accesos	Conjunto de procesos y tecnologías para administrar usuarios, cuentas, autenticación, altas, bajas y permisos.
KPI	Key Performance Indicator	Indicador clave de rendimiento	Mide si un proceso, control u objetivo se está cumpliendo correctamente. Ejemplo: porcentaje de equipos actualizados.
KRI	Key Risk Indicator	Indicador clave de riesgo	Advierte de que la exposición al riesgo está aumentando o se aproxima a un nivel no aceptable.
LMS	Learning Management System	Sistema de gestión del aprendizaje	Plataforma utilizada para impartir y registrar formación. Moodle es un ejemplo de LMS.
MFA	Multi-Factor Authentication	Autenticación multifactor	Requiere dos o más factores para autenticar a un usuario, por ejemplo contraseña más aplicación móvil o llave de seguridad.
MTTR	Mean Time To Remediate	Tiempo medio de remediación	En este documento mide el tiempo medio necesario para corregir vulnerabilidades: tiempo total de resolución dividido entre casos resueltos.
OpenVAS	Open Vulnerability Assessment System	Sistema abierto de evaluación de vulnerabilidades	Escáner utilizado para detectar vulnerabilidades conocidas y configuraciones inseguras en sistemas y servicios.
RA1	Resultado de Aprendizaje 1	Resultado de Aprendizaje 1	Referencia curricular del módulo: desarrollar planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección.
RACI	Responsible, Accountable, Consulted, Informed	Responsable, Aprobador/Responsable último, Consultado e Informado	Matriz para determinar quién ejecuta (R), quién responde y aprueba (A), quién debe ser consultado (C) y quién informado (I).
RRHH	Recursos Humanos	Recursos Humanos	Departamento que participa en formación, comunicación, gestión de personal y tratamiento organizativo de determinados incumplimientos.
SIEM	Security Information and Event Management	Gestión de información y eventos de seguridad	Plataforma que centraliza registros de múltiples sistemas, correlaciona eventos y genera alertas de seguridad.
SLA	Service Level Agreement	Acuerdo de nivel de servicio	Define compromisos medibles, como el plazo máximo de corrección de una vulnerabilidad o de atención de un servicio.
VPN	Virtual Private Network	Red privada virtual	Permite establecer una conexión cifrada entre un usuario remoto y la red o los recursos de la empresa.

1. Por qué medir una política de seguridad

Una política de seguridad no puede considerarse eficaz únicamente porque haya sido redactada y aprobada. Debe existir evidencia de que se aplica, se cumple y produce los resultados esperados. Para ello se utilizan indicadores medibles.

Idea clave: una política sin métricas permite afirmar que existe; una política con métricas permite comprobar si funciona.

2. Qué es un KPI de ciberseguridad

Un KPI (Key Performance Indicator) es un indicador cuantificable utilizado para comprobar el grado de cumplimiento de un objetivo relevante. En ciberseguridad, puede medir cobertura de controles, cumplimiento, tiempos de respuesta, formación, vulnerabilidades, copias de seguridad o exposición al riesgo.

Concepto	Pregunta
Objetivo	¿Qué queremos conseguir?
KPI	¿Qué dato mediremos para saber si lo conseguimos?
Fórmula	¿Cómo se obtiene el valor?
Fuente	¿De dónde salen los datos?
Periodicidad	¿Cada cuánto se mide?
Responsable	¿Quién debe obtener y revisar el dato?
Umbral	¿Qué valor consideramos aceptable?
Acción	¿Qué hacemos si el indicador no cumple?

3. Cómo se calcula un KPI

3.1. KPI porcentual

Cuando queremos conocer qué parte de una población cumple un requisito, utilizamos habitualmente un porcentaje:

$$\text{KPI (\%)} = (\text{elementos que cumplen} / \text{elementos totales}) \times 100$$

Ejemplo: si hay 120 equipos corporativos y 108 tienen instalados los parches críticos, el KPI de equipos actualizados será: $108 / 120 \times 100 = 90 \%$.

3.2. KPI de tiempo medio

Algunos indicadores se expresan en tiempo. Por ejemplo, el tiempo medio de corrección de vulnerabilidades (MTTR):

$$\text{MTTR} = \text{suma del tiempo de resolución} / \text{número de casos resueltos}$$

Si tres vulnerabilidades tardaron 2, 5 y 8 días en corregirse, el MTTR será $(2 + 5 + 8) / 3 = 5$ días.

3.3. KPI de conteo

Otros indicadores no necesitan una fórmula compleja. Se expresan simplemente como una cantidad: número de excepciones caducadas, número de incidentes comunicados, número de cuentas privilegiadas sin MFA, etc.

4. Un KPI necesita un objetivo o umbral

El valor de un KPI no indica por sí solo si la situación es adecuada. Debe compararse con un objetivo, nivel mínimo o umbral aprobado.

KPI	Resultado	Objetivo	Interpretación
Equipos actualizados	92 %	$\geq 95 \%$	No cumple
MFA en cuentas privilegiadas	100 %	100 %	Cumple
Formación completada	85 %	$\geq 95 \%$	No cumple
Excepciones caducadas activas	2	0	No cumple
Accesos de proveedores revisados	100 %	100 %	Cumple

5. Características de un buen KPI

- **Relevante:** debe estar ligado a un objetivo o control de seguridad.
- **Medible:** debe poder obtenerse de datos reales.
- **Trazable:** debe conocerse la fuente del dato.
- **Periódico:** debe medirse con una frecuencia definida.
- **Responsable:** debe existir una persona o rol que lo revise.
- **Comparable:** debe poder observarse su evolución en el tiempo.
- **Accionable:** un resultado deficiente debe provocar una decisión o acción correctiva.

6. KPIs recomendados para una Política General de Seguridad

KPI	Fórmula / medida	Fuente	Periodicidad	Objetivo orientativo
Equipos actualizados	$\text{Actualizados} / \text{total} \times 100$	Gestor de parches / inventario	Mensual	$\geq 95 \%$
MFA en cuentas privilegiadas	$\text{Cuentas con MFA} / \text{cuentas privilegiadas} \times 100$	IAM / directorio	Mensual	100 %
Usuarios formados	$\text{Usuarios formados} / \text{usuarios obligados} \times 100$	LMS / Moodle	Trimestral	$\geq 95 \%$
Tasa de clic en phishing	$\text{Usuarios que hacen clic} / \text{usuarios expuestos} \times 100$	Campaña simulada	Por campaña	$\leq 10 \%$
Tasa de reporte	$\text{Usuarios que reportan} / \text{usuarios expuestos} \times 100$	Campaña simulada	Por campaña	$\geq 60 \%$
Vulnerabilidades críticas corregidas	$\text{Críticas corregidas} / \text{críticas detectadas} \times 100$	OpenVAS / ticketing	Mensual	$\geq 95 \%$
Excepciones caducadas	Número de excepciones vencidas aún activas	Registro de excepciones	Mensual	0
Backups verificados	$\text{Restauraciones correctas} / \text{pruebas realizadas} \times 100$	Registro de backup	Mensual / trimestral	100 %
MTTR vulnerabilidades	Días totales / vulnerabilidades cerradas	Ticketing	Mensual	Según política
Accesos de proveedores revisados	$\text{Accesos revisados} / \text{accesos externos} \times 100$	IAM / contratos	Trimestral	100 %

7. Ejemplo completo: de la política al KPI

Elemento	Ejemplo
Requisito de política	Todos los equipos corporativos deben aplicar las actualizaciones críticas.
Objetivo	Mantener una cobertura de parcheo igual o superior al 95 %.
KPI	Porcentaje de equipos con actualizaciones críticas aplicadas.
Fórmula	$\text{Equipos actualizados} / \text{total de equipos} \times 100$.
Datos	108 equipos actualizados de 120.
Resultado	90 %.
Umbral	$\geq 95 \%$.
Conclusión	No cumple.
Acción	Identificar los 12 equipos pendientes, asignar responsable y plazo y repetir la medición.

8. Qué es un KRI y en qué se diferencia de un KPI

Un KRI (Key Risk Indicator) es un indicador que advierte de que la exposición al riesgo de la organización está aumentando o se aproxima a un nivel no aceptable. Mientras un KPI mide si un proceso o control funciona como se espera, un KRI ayuda a anticipar situaciones que pueden convertirse en incidentes o pérdidas relevantes.

Idea clave

KPI = ¿estamos haciendo bien lo que hemos decidido hacer?

KRI = ¿está aumentando el riesgo para la organización?

Aspecto	KPI	KRI
Pregunta principal	¿Se cumple el objetivo o control?	¿Está aumentando nuestra exposición al riesgo?
Enfoque	Rendimiento, eficacia y cumplimiento	Riesgo, tendencia y señales de deterioro
Ejemplo	% de equipos actualizados	Nº de vulnerabilidades críticas fuera de plazo
Interpretación	Compara resultado con un objetivo	Compara exposición con un umbral de tolerancia
Decisión típica	Corregir el proceso o mejorar el control	Priorizar, escalar, reducir o aceptar formalmente el riesgo

8.1. Cómo se define un KRI

Un KRI debe estar vinculado a un riesgo concreto y tener una fuente de datos, una periodicidad, un responsable y un umbral de alerta. No todos los KRI se calculan mediante porcentajes: muchos son conteos, antigüedad, acumulación de excepciones o tendencias.

Elemento	Pregunta
Riesgo asociado	¿Qué riesgo queremos vigilar?
Indicador	¿Qué señal observable nos avisa de que aumenta?
Fuente	¿De dónde obtenemos el dato?
Periodicidad	¿Cada cuánto debe revisarse?
Umbral	¿A partir de qué valor debemos actuar o escalar?
Responsable	¿Quién revisa el KRI y activa la respuesta?
Acción	¿Qué haremos si supera el umbral?

8.2. KRI recomendados para una Política General de Seguridad

KRI	Medida	Fuente	Periodicidad	Umbral orientativo
Vulnerabilidades críticas fuera de SLA	Nº de vulnerabilidades críticas cuyo plazo de corrección ha vencido	OpenVAS / ticketing	Semanal / mensual	0
Sistemas EOL/EOS	Nº de sistemas sin soporte o fin de vida	Inventario / CMDB	Mensual	0 en activos críticos
Cuentas privilegiadas sin revisión	Nº de cuentas privilegiadas cuya revisión periódica está vencida	IAM / directorio	Mensual	0
Activos expuestos a Internet sin propietario	Nº de activos publicados sin responsable identificado	Inventario / escaneo externo	Mensual	0
Proveedores críticos sin evaluación vigente	Nº de proveedores críticos con evaluación caducada	Contratos / registro de terceros	Trimestral	0
Excepciones de alto riesgo abiertas	Nº de excepciones de riesgo alto/crítico aún vigentes	Registro de excepciones	Mensual	Tendencia a 0
Restauraciones fallidas	Nº de pruebas de restauración fallidas en el periodo	Registro de backup	Mensual / trimestral	0
Fuentes críticas sin telemetría >24 h	Nº de fuentes críticas que no envían registros durante más de 24 horas	SIEM / monitorización	Diaria	0

8.3. Ejemplo conjunto: KPI verde y KRI rojo

Supongamos que GalileoTechSolutions dispone de 120 equipos y 115 están correctamente actualizados. El KPI de parcheado es $115 / 120 \times 100 = 95,8 \%$, por lo que cumple el objetivo $\geq 95 \%$. Sin embargo, uno de los cinco equipos pendientes es un servidor web crítico expuesto a Internet y mantiene una vulnerabilidad crítica cuyo SLA ha vencido.

Indicador	Tipo	Resultado	Umbral	Interpretación
Equipos actualizados	KPI	95,8 %	$\geq 95 \%$	Cumple: el proceso global de parcheado alcanza el objetivo.
Vulnerabilidades críticas fuera de SLA	KRI	1	0	Alerta: existe una exposición concreta que requiere actuación prioritaria.

Conclusión

Un KPI correcto no garantiza que el riesgo sea bajo. KPI y KRI deben revisarse conjuntamente: los KPI muestran el desempeño de los controles y los KRI muestran señales de exposición o deterioro del riesgo.

9. KPI y KRI dentro del ciclo de vida de una política

Los KPI y los KRI no son elementos aislados. Se utilizan durante la implantación, supervisión, auditoría y revisión de la política. Los KPI muestran si los controles y procesos alcanzan sus objetivos; los KRI permiten detectar si la exposición al riesgo aumenta aunque algunos KPI sean satisfactorios.

Necesidad → Redacción → Revisión → Aprobación → Comunicación → Implantación → Medición mediante KPI y KRI → Gestión de excepciones e incumplimientos → Auditoría → Revisión y nueva versión

Los resultados de KPI y KRI deben alimentar la revisión. Un KPI que incumple de forma recurrente puede indicar un problema de proceso o control. Un KRI que supera su umbral puede exigir priorización inmediata, controles compensatorios, escalado al responsable de seguridad o aceptación formal del riesgo.

10. Actividad de clase: Simulacro de Comité de Seguridad

Esta actividad se realiza después de haber trabajado KPI y KRI. El alumnado deberá crear y gestionar una Política General de Seguridad, utilizar indicadores para comprobar su aplicación y distinguir entre rendimiento de los controles y exposición al riesgo.

10.1. Objetivos

- Definir correctamente el alcance de una política de seguridad.
- Asignar responsabilidades entre dirección, seguridad, sistemas, usuarios y proveedores.
- Comprender quién redacta, aprueba, ejecuta, supervisa y revisa una política.
- Gestionar excepciones e incumplimientos de forma documentada.
- Definir KPI y KRI, calcularlos e interpretarlos para tomar decisiones.
- Comprender que un KPI favorable puede coexistir con un KRI en situación de alerta y justificar la decisión adecuada.
- Comprender el ciclo de vida completo de una política.

10.2. Escenario

GalileoTechSolutions es una empresa de 120 empleados con trabajo presencial y remoto. Dispone de servidores internos, servicios cloud, VPN, portátiles corporativos y varios proveedores con acceso remoto. Una auditoría reciente ha detectado contraseñas débiles, software sin actualizar, cuentas antiguas, permisos excesivos, equipos sin bloqueo automático y accesos de terceros no revisados. La Dirección decide implantar una Política General de Seguridad.

10.3. Roles

Rol	Responsabilidad principal
Dirección	Aprueba la política, asigna recursos y acepta determinados riesgos.
Responsable de Seguridad	Coordina, mantiene y supervisa el cumplimiento de la política.
Sistemas	Implanta controles técnicos y mantiene configuraciones seguras.
Usuarios / RRHH	Cumplen normas, comunican incidentes y participan en formación.
Proveedores	Cumplen los requisitos contractuales y de acceso establecidos.
Auditor / Secretario	Registra decisiones, evidencias, excepciones e incumplimientos.

10.4. Fase 1 — Definir el alcance

El grupo debe decidir a quién, a qué información, a qué tecnologías y a qué ubicaciones se aplica la política. Debe incluir empleados, directivos, personal temporal, proveedores, equipos, servicios cloud, cuentas, datos, teletrabajo y acceso remoto cuando corresponda.

Producto: un apartado de alcance de un máximo de 10 líneas.

10.5. Fase 2 — Asignar responsabilidades mediante RACI

Función	Dirección	Seguridad	Sistemas	Usuarios	Proveedores
Aprobar política					
Mantener política					
Aplicar controles técnicos					
Cumplir normas					
Comunicar incidentes					
Autorizar excepciones					
Revisar accesos					
Gestionar actualizaciones					

R = ejecuta; A = responsable último/aprueba; C = consultado; I = informado.

10.6. Fase 3 — Aprobación por Dirección

Cada grupo presenta su política a la Dirección. Esta deberá plantear objeciones sobre coste, alcance, responsabilidad o viabilidad. La política solo se considera vigente cuando queda formalmente aprobada y contiene versión, fecha de aprobación, responsable y fecha prevista de revisión.

10.7. Inyector 1 — Solicitud de excepción

Situación: un proveedor necesita durante tres meses una herramienta de acceso remoto prohibida por la nueva política porque mantiene una aplicación legacy.

El grupo deberá decidir si rechaza la solicitud o aprueba una excepción. Si la aprueba, debe documentar: norma afectada, motivo, riesgo, controles compensatorios, responsable que autoriza, duración y fecha de revisión.

10.8. Inyector 2 — Incumplimiento

Situación: un empleado instala software no autorizado en un equipo corporativo.

El grupo deberá determinar si existe incumplimiento, quién interviene, qué evidencia se conserva, qué acción correctiva se aplica y si procede formación, advertencia o escalado. Debe diferenciarse claramente una excepción autorizada de un incumplimiento no autorizado.

10.9. Inyector 3 — Cambio tecnológico

Situación: seis meses después la organización autoriza BYOD para determinados empleados.

El grupo debe revisar el alcance y decidir qué cambios son necesarios en cifrado, MFA, borrado remoto, protección de datos, responsabilidades y acceso. Debe indicar si el cambio requiere una versión menor o mayor de la política.

10.10. Inyector 4 — Auditoría, KPI y KRI

Un año después se obtienen los siguientes resultados:

Indicador observado	Tipo	Resultado	Objetivo / umbral
Equipos actualizados	KPI	92 %	≥ 95 %
MFA en cuentas administrativas	KPI	100 %	100 %
Usuarios que completaron formación	KPI	85 %	≥ 95 %
Accesos de proveedores revisados	KPI	80 %	100 %
Equipos con bloqueo automático	KPI	95 %	100 %
Excepciones caducadas aún activas	KPI	2	0
Vulnerabilidades críticas fuera de SLA	KRI	2	0
Sistemas EOL/EOS en activos críticos	KRI	1	0

Indicador observado	Tipo	Resultado	Objetivo / umbral
Cuentas privilegiadas con revisión vencida	KRI	1	0
Pruebas de restauración fallidas	KRI	1	0

El grupo debe: 1) distinguir qué indicadores son KPI y cuáles son KRI; 2) identificar KPI que cumplen o no cumplen; 3) detectar KRI que superan el umbral de tolerancia; 4) calcular, cuando sea posible, los valores a partir de datos brutos; 5) asignar responsable; 6) proponer acciones correctivas o de reducción del riesgo; 7) decidir qué aspectos de la política necesitan revisión.

10.11. Producto final

- Política General de Seguridad v1.0 (2–4 páginas).
- Matriz RACI de responsabilidades.
- Registro de la excepción del proveedor.
- Registro del incumplimiento del empleado.
- Cuadro de mando de KPI y KRI con fórmula/medida, fuente, periodicidad, responsable, objetivo/umbral, resultado y acción.
- Acta del Comité de Seguridad con decisiones y próxima revisión.

10.12. Plantilla mínima de KPI/KRI para la actividad

Indicador	Tipo	Fórmula / medida	Fuente	Periodicidad	Responsable	Objetivo / umbral	Resultado	Acción

10.13. Evaluación

Elemento	Puntuación
Alcance de la política	1 punto
Roles y responsabilidades	2 puntos
Aprobación y ciclo de vida	1 punto
Gestión de excepciones	1,5 puntos
Gestión de incumplimientos	1,5 puntos
Definición, cálculo e interpretación de KPI y KRI	2 puntos
Defensa ante el comité	1 punto
TOTAL	10 puntos

10.14. Cierre del simulacro

Conclusión que debe alcanzar el alumnado: una Política de Seguridad no termina cuando se redacta. Debe aprobarse, comunicarse, implantarse, medirse mediante KPI, vigilarse mediante KRI, gestionar excepciones e incumplimientos, auditarse y revisarse durante todo su ciclo de vida.